



# 자산 분석 및 위험 관리 방법

자산분석 및 위험관리 지침에 따른 위험분석/평가 결과 및 위험관리 계획 보고

## 1. 자산분석 및 위험관리 절차



- 1) 자산분석 : 관리되어야 할 자산 파악 및 중요도 평가 수행
- 2) 위험식별 : 위험 및 취약성에 따른 위험 식별
- 3) 위험분석 : 위험 및 취약성에 따른 위험 식별
- 4) 위험평가 : 자산에 대한 위험평가 수행
- 5) 위험관리 : 도출된 위험에 대한 위험 관리 계획 수립 등 관리 방안 마련

## 2. 자산분석

- 자산\_목록관리 대장을 통해 다음과 같은 자산을 분류하여 현행화 한다.

| No | 분류            | 설명                                                         | 코드명 | 비고                               |
|----|---------------|------------------------------------------------------------|-----|----------------------------------|
| 1  | 서버            | 사용자에게 특정 서비스를 제공하기 위한 기능의 운영체제 및 프로그램이 설치되어 있는 장비          | SRV | Windows / Linux / Unix Server 등  |
| 2  | AWS Resource  | 사용자에게 특정 서비스를 제공하기 위한 기능의 운영체제 및 프로그램이 설치되어 있는 장비          | AWS | Windows / Linux / Unix Server 등  |
| 3  | 정보보호시스템       | 서비스 보안 운영을 위한 장비                                           | SEC | 방화벽, VPN 등                       |
| 4  | 네트워크 장비       | 서비스 운영 및 제반 업무를 위해 설치된 네트워크 장비                             | NW  | 공유기, 라우터, 허브, 스위치(L4/L3/L2) 등    |
| 5  | DBMS          | 사용자가 데이터에 접근하여 데이터를 저장 및 관리 등의 기능을 제공하는 응용 소프트웨어           | DB  | MySQL, Oracle, MSSQL, MariaDB 등  |
| 6  | WAS           | Tomcat, NginX 등 패치가 필요한 어플리케이션                             | WAS | Tomcat, Apache, NginX 등          |
| 7  | Storage       | MA, MBP 서비스를 제공하기 위한 목적으로 사용되는 스토리지 모인 중요 정보를 보관하고 있는 스토리지 | STO | S3, Google Drive 등               |
| 8  | 웹 사이트         | 회사, 제품, 판매 등 정보 및 서비스를 제공하기 위하여 인터넷상 구축·운영되는 서비스           | WEB | - MA, MBP 웹 서비스<br>- MA IOS, AOS |
| 9  | OS 이미지        | 서비스 배포를 위한 OS 이미지                                          | IMG |                                  |
| 10 | PC (업무용, 운영용) | 모인 서비스 업무 및 운영에 접속하기 위한 단말기                                | PC  | 데스크탑, 노트북 등                      |

### 3. 위험 식별

- 서버 등 인프라 자산 : 인프라 취약점 점검
- 웹/앱 서비스 : 웹/앱 홈페이지 취약점 점검
- 정보보호 관리체계 : 정보보호 관리체계 점검

### 4. 위험 분석

- 서버 등 인프라 자산 : 기준선 접근법
  - 영향도 : 자산 중요도 + 취약점 등급
    - 상 = 9 이상, 중 = 8 이하 ~ 5이상, 하 = 5 이하
  - 자산 중요도 : 기밀성(상/중/하) + 무결성(상/중/하) + 가용성(상/중/하)
    - 상 = 3, 중 = 2, 하 = 1
      - 상 : 모인 서비스 운영 자산
      - 중 : 모인 서비스를 관리하기 위한 자산(보안 자산 포함)
      - 하 : 모인 서비스 및 관리 외 자산
  - 취약점 등급(금감원 기준) :
    - 높음 = 5, 다소 높음 = 4, 보통 = 3, 다소낮음 = 2, 낮음 = 1
- 웹/앱 서비스 : 기준선 접근법
  - 영향도 : 서비스 중요도 + 취약점 등급
    - 상 = 9 이상, 중 = 8 이하 ~ 5이상, 하 = 5 이하
  - 서비스 중요도 : 기밀성(상/중/하) + 무결성(상/중/하) + 가용성(상/중/하)
    - 상 = 3, 중 = 2, 하 = 1
      - 상 : 모인 서비스 Web/APP
      - 중 : 모인 서비스를 운영 관리하기 위한 (Admin 등 관리자) Web/APP
      - 하 : 모인 서비스 및 운영 관리외 Web/APP
  - 취약점 등급(금감원 기준) :
    - 높음 = 5, 다소 높음 = 4, 보통 = 3, 다소낮음 = 2, 낮음 = 1
- 정보보호 관리체계 : 복합적 접근법
  - 영향도 : 법적 준거성 + 취약점 등급
    - 상 = 6 이상, 중 = 5 이하 ~ 4이상, 하 = 3 이하
  - 법적 준거성 : 필수 = 3, 권고 = 2, 없음 = 1
  - 취약점 등급(금감원 기준) :
    - 높음 = 5, 다소 높음 = 4, 보통 = 3, 다소낮음 = 2, 낮음 = 1

### 5. 위험 평가

- 위험도 = 영향도(상/중/하) + 침해(장애) 발생가능성(고/저) + 비용 및 소요시간(저/중/고)

- 영향도 : 상 = 3, 중 = 2, 하 = 1
- 발생 가능성 : 고 = 3, 저 = 1
  - 고 = 유사한 위험으로 침해사고가 사례가 있거나 관련성이 높음
  - 저 = 발생 가능성이 낮음
- 비용 및 소요 시간 : 저 = 3, 중 = 2, 고 = 1
  - 저 = 비용 및 인력이 연간 계획에 포함되어 있음
  - 중 = 비용 및 인력이 내년 계획에 포함할 계획
  - 고 = 비용 및 인력에 대한 계획이 수립되지 않음
- DOA (수용 가능한 위험 수준) : 위험도 5 이하 수용

## 6. 위험 관리

- 1) 위험감소(Mitigation): 위험을 감소시킬 수 있는 대책을 마련하여 구현
- 2) 위험회피(Avoidance): 위험이 존재하는 자산을 제거
- 3) 위험수용(Acceptance): 위험을 받아들이고 잠재적 손실 비용을 감수
- 4) 위험전가(Transfer): 보험이나 외주 등으로 잠재적 비용을 제3자에게 이전

## 7. 보고

- 위험 평가 결과서 : CISO 보고
- 위험관리 계획서 : 정보보호위원회의 심의·의결을 통해 대표이사의 승인 후 이사회 보고

---

 위험 평가 결과서

---

 위험 관리 계획서

 위험 관리 이사회 보고